

OVERVIEW

This document contains the complete Compass gap assessment questionnaire. It covers six categories: the four NIST AI RMF functions (Govern, Map, Measure, Manage), a GenAI-specific section, a Vendor and Procurement section, and conditional questions triggered by detection results.

Scoring: Yes = 100 pts | Partial = 50 pts | No = 0 pts | Unsure = 0 pts (flagged for follow-up). Assessment Score = 100 minus the compliance percentage. Higher score = more governance gaps.

THE ID FORMULA

Every question ID follows one rule: PREFIX - NUMBER The prefix identifies the section. The number identifies the question within that section. Always two parts, always separated by a hyphen.

Example breakdown:

ME PREFIX	-	03 NUMBER	ME-03 = Measure, question 3
---------------------	---	---------------------	---------------------------------------

The prefix is always letters derived from the NIST AI RMF function name or section name. The number is always 2 digits, zero-padded (01 not 1, 09 not 9). Questions are numbered sequentially within their section starting from 01.

WHY EACH PREFIX WAS CHOSEN

Each prefix is chosen to be immediately readable — someone looking at an ID should know which section it belongs to without needing a lookup table. The prefixes avoid clashing with each other, which is why Measure is ME and Manage is MG rather than both being M.

G-NN 10 questions G-01 to G-10	GOVERN — Organizational Policies & Accountability Why this prefix: G is the first letter of Govern. Short, obvious, no conflicts with other sections. Example ID: G-01 = Govern section, question 1 — Written AI usage policy Sequential numbering: Always 2 digits, zero-padded. 01, 02, 03 ... never 1, 2, 3.
---	---

M-NN

10 questions
M-01 to M-10

MAP — AI Tool Inventory & Risk Awareness

Why this prefix: M is the first letter of Map. Map is the shortest function name so a single letter works cleanly.

Example ID: **M-03** = Map section, question 3 — Data handling practices reviewed

Sequential numbering: Always 2 digits, zero-padded. 01, 02, 03 ... never 1, 2, 3.

ME-NN

10 questions
ME-01 to ME-10

MEASURE — Monitoring & Ongoing Risk Measurement

Why this prefix: ME uses the first two letters of Measure. A single M would clash with Map, so the second letter E is added to distinguish them.

Example ID: **ME-02** = Measure section, question 2 — Alerts for new AI tools

Sequential numbering: Always 2 digits, zero-padded. 01, 02, 03 ... never 1, 2, 3.

MG-NN

10 questions
MG-01 to MG-10

MANAGE — Response & Remediation Capability

Why this prefix: MG uses M + G (the second consonant of Manage). Cannot use MA because Map already owns M, and ME is Measure. MG is unambiguous.

Example ID: **MG-05** = Manage section, question 5 — Escalation path and response timeline

Sequential numbering: Always 2 digits, zero-padded. 01, 02, 03 ... never 1, 2, 3.

GA-NN

12 questions
GA-01 to GA-12

GENAI — Generative AI Specific Controls

Why this prefix: GA stands for GenAI. G alone belongs to Govern, so the second letter A (from the word AI) is added. GA is unique across all prefixes.

Example ID: **GA-08** = GenAI section, question 8 — Prompt injection training

Sequential numbering: Always 2 digits, zero-padded. 01, 02, 03 ... never 1, 2, 3.

V-NN

10 questions
V-01 to V-10

VENDOR — Procurement & Third-Party AI Controls

Why this prefix: V stands for Vendor. No other section starts with V so a single letter is sufficient and clean.

Example ID: **V-03** = Vendor section, question 3 — SOC 2 requirement for AI vendors

Sequential numbering: Always 2 digits, zero-padded. 01, 02, 03 ... never 1, 2, 3.

C-NN

7 questions
C-01 to C-07

CONDITIONAL — Triggered by Detection Results

Why this prefix: C stands for Conditional. These questions are not part of the standard flow — C immediately signals they are context-dependent and detection-triggered.

Example ID: **C-04** = Conditional question 4 — Unclassified AI tool traffic process

Sequential numbering: Always 2 digits, zero-padded. 01, 02, 03 ... never 1, 2, 3.

NUMBERING RULES

Rule	Correct	Wrong
Always 2 digits, zero-padded	G-01, G-09, G-10	G-1, G-9, G-10
Start at 01, not 00	G-01 is the first question	G-00 is never used
Number sequentially, no gaps	G-01, G-02, G-03...	G-01, G-03, G-05 (skip)
Each section restarts at 01	G-01...G-10, then M-01...M-10	G-01...G-10, then M-11...M-20
Never reuse an ID across sections	G-01 and M-01 are different questions	Using G-01 to mean two things
New questions added at the end	G-11 comes after G-10	Inserting G-04b between G-04 and G-05

FULL ID REGISTRY

Every question ID currently in the Compass questionnaire, in order.

GOVERN (G-01 to G-10)

ID	Question Summary
G-01	Written AI usage policy defining approved and prohibited uses
G-02	Designated owner or team responsible for AI governance decisions
G-03	Employees required to review and acknowledge AI usage policies
G-04	AI policies reviewed and updated at least once per year
G-05	Policy explicitly addresses generative AI tools (LLMs, image gen, voice synthesis)
G-06	Defined consequences for employees who violate the AI usage policy
G-07	Executive or board-level sponsor accountable for AI risk
G-08	AI governance policies communicated to contractors, vendors, and third parties
G-09	AI tools classified by risk tier (approved, conditional, prohibited)
G-10	Formal process for employees to request approval for a new AI tool

MAP (M-01 to M-10)

ID	Question Summary
M-01	Formal inventory of all AI tools in use across departments
M-02	Data handling practices of each AI tool reviewed
M-03	Understanding of which AI tools have access to sensitive or confidential data
M-04	Formal risk assessment conducted for AI tools in use
M-05	AI inventory includes department, owner, business purpose, and data classification
M-06	Data processing agreements (DPAs) tracked per AI tool
M-07	Regulated data (PII, HIPAA, GDPR, CCPA) identified per AI tool
M-08	AI tools on remote/personal devices tracked and included in inventory
M-09	AI tool supply chain evaluated including embedded third-party models
M-10	Process to detect when a vendor adds AI to an existing approved product

MEASURE (ME-01 to ME-10)

ID	Question Summary
ME-01	AI tool usage monitored in SIEM, proxy, or equivalent logging system
ME-02	Alerts configured for new or unknown AI tools accessed on the network
ME-03	AI-related security incidents tracked and reviewed on a regular schedule
ME-04	Periodic reviews of the AI tool inventory for newly adopted tools
ME-05	Volume and frequency of data sent to external AI tools monitored
ME-06	DNS or proxy logs reviewed specifically for AI-related domains on a schedule
ME-07	Mechanism to detect AI tool access from unmanaged devices or personal networks
ME-08	AI risk metrics reported to leadership on a regular basis
ME-09	Baseline of normal AI tool usage established to detect anomalies
ME-10	AI tools re-evaluated when a vendor updates privacy policy or terms of service

MANAGE (MG-01 to MG-10)

ID	Question Summary
MG-01	Defined process to block or restrict unauthorized AI tools
MG-02	Vendor review process for AI tools before organizational adoption
MG-03	Incident response plan covers AI-related data exposure events
MG-04	AI tool owners formally assigned for each approved tool
MG-05	Documented escalation path and response timeline for unauthorized tool detection

ID	Question Summary
MG-06	Ability to revoke AI tool access across all users within 24 hours
MG-07	IR plan defines what constitutes an AI-related security incident
MG-08	Post-incident review conducted and controls updated after AI incidents
MG-09	Process for employees to report suspected AI misuse or policy violations
MG-10	Firewall and DNS blocking rules for AI tools tested and verified

GENAI (GA-01 to GA-12)

ID	Question Summary
GA-01	Policy addresses AI-generated media including deepfakes and synthetic images
GA-02	Controls in place around AI voice synthesis and audio cloning tools
GA-03	Guest and contractor accounts restricted from accessing AI tools on corporate network
GA-04	Process to investigate and identify unrecognized AI tool traffic in network logs
GA-05	Employees prohibited from entering PII into consumer AI tools without a DPA
GA-06	Employees prohibited from entering proprietary source code or trade secrets into AI tools
GA-07	Guidance on verifying AI-generated outputs before acting on or sharing them
GA-08	Employees trained specifically on prompt injection attack risks
GA-09	Policy covering use of AI for customer-facing communications or content
GA-10	Controls preventing AI from generating content that impersonates executives or brand
GA-11	Evaluation of whether AI tools in use could produce CBRN-relevant information
GA-12	Process to evaluate AI-assisted decisions for bias or discriminatory outcomes

VENDOR (V-01 to V-10)

ID	Question Summary
V-01	Vendor review includes AI security checklist covering data handling and compliance
V-02	AI vendors required to disclose whether customer data trains or fine-tunes models
V-03	SOC 2 Type II compliance required for AI vendors processing company data
V-04	AI vendors contractually required to notify of data breach within defined timeframe
V-05	Contracts with AI vendors include right to audit data handling and security

ID	Question Summary
V-06	Process to re-evaluate vendor risk after acquisition, major changes, or model updates
V-07	Knowledge of whether approved AI vendors subcontract to fourth-party providers
V-08	AI features embedded in non-AI software tracked and governed under AI policy
V-09	Maximum data retention requirement contractually enforced with AI vendors
V-10	Formal offboarding process when an AI vendor relationship is terminated

CONDITIONAL (C-01 to C-07)

ID	Question Summary	Trigger Condition
C-01	Policy addresses deepfakes and synthetic images	Image generation tool detected
C-02	Controls around AI voice synthesis or audio cloning tools	Voice/audio generation tool detected
C-03	Guest/contractor accounts restricted from AI tools on corporate network	'guest' username observed in logs
C-04	Process to investigate unrecognized AI tool traffic	Unknown/unclassified domain detected
C-05	Controls governing AI coding assistants that send code to external APIs	Code assistant tool detected
C-06	Open source AI models subject to same governance review as commercial tools	OSS model host detected
C-07	Policy for AI transcription tools that may capture confidential conversations	Transcription tool detected

HOW TO ADD NEW QUESTIONS

Rule: always add to the end of the relevant section. Never insert in the middle and never reuse a retired ID.

Step	Action	Detail
1	Pick the right section	Does it belong to Govern, Map, Measure, Manage, GenAI, Vendor, or Conditional?
2	Find the last ID in that section	e.g. if Govern currently ends at G-10, the next ID is G-11
3	Assign the next sequential number	Always 2 digits. G-11 not G-11a, not G-10b
4	Map it to a NIST control	Every question must reference at least one NIST AI RMF control ID

Step	Action	Detail
5	Assign a gap severity	HIGH, MEDIUM, or LOW based on the control's severity_weight in the registry
6	Write the scoring logic	Yes=100 Partial=50 (describe what partial means) No=0 Unsure=0, flagged
7	Update the JSON schema	Add the new question to 04_json_schema.json and the questionnaire JSON

Prefix	Section	Count	ID Range
G-	Govern	10	G-01 to G-10
M-	Map	10	M-01 to M-10
ME-	Measure	10	ME-01 to ME-10
MG-	Manage	10	MG-01 to MG-10
GA-	GenAI Specific	12	GA-01 to GA-12
V-	Vendor	10	V-01 to V-10
C-	Conditional	7	C-01 to C-07
	TOTAL	59	

QUESTION COUNT BY SECTION

#	Section	Questions	Focus
1	GOVERN — Policies & Accountability	10	Written policy, ownership, training, classification
2	MAP — Inventory & Risk Awareness	10	Tool inventory, DPAs, data classification, supply chain
3	MEASURE — Monitoring & Measurement	10	SIEM coverage, DNS review, anomaly detection, metrics
4	MANAGE — Response & Remediation	10	Blocking, IR plan, escalation, revocation, post-incident
5	GENAI — Generative AI Specific Controls	12	Deepfakes, voice, code AI, PII, prompt injection, bias
6	VENDOR — Procurement & Third-Party AI	10	Vendor review, DPA, SOC 2, breach notice, offboarding

#	Section	Questions	Focus
7	CONDITIONAL — Triggered by Detection	7	Unlocked dynamically based on DNS scan results
	TOTAL	59	

GOVERN — ORGANIZATIONAL POLICIES & ACCOUNTABILITY

Does the organization have the policies, ownership structures, and training needed to govern AI responsibly?

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
G-01	Does your organization have a written AI usage policy that defines approved and prohibited uses?	Govern 1.1	HIGH	Yes=100 Partial=50 (draft exists, not published) No=0 Unsure=0, flagged	GV.PO-1	Data Privacy, IP Exposure
G-02	Is there a designated owner or team responsible for AI governance decisions?	Govern 1.2	MEDIUM	Yes=100 Partial=50 (informal owner, no formal mandate) No=0 Unsure=0, flagged	GV.OV-2	Human-AI Config
G-03	Are employees required to review and acknowledge AI usage policies?	Govern 1.3	MEDIUM	Yes=100 Partial=50 (awareness exists, no formal acknowledgment) No=0 Unsure=0, flagged	GV.AT-1	Harmful Content, IP Exposure

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
G-04	Does your organization review and update AI policies at least once per year?	Govern 1.7	LOW	Yes=100 Partial=50 (ad hoc review only) No=0 Unsure=0, flagged	GV.PO-2	Confabulation
G-05	Does your AI usage policy explicitly address the use of generative AI tools such as large language models, image generators, and voice synthesis tools?	Govern 1.1	HIGH	Yes=100 Partial=50 (general AI policy only, no GenAI specifics) No=0 Unsure=0, flagged	GV.PO-1	Data Privacy, IP Exposure, Info Integrity
G-06	Are there defined consequences for employees who violate the AI usage policy?	Govern 1.3	MEDIUM	Yes=100 Partial=50 (policy references HR but no specific consequences) No=0 Unsure=0, flagged	GV.PO-1 , GV.AT-1	Harmful Content, Info Security
G-07	Does your organization have an executive or board-level sponsor	Govern 1.2	MEDIUM	Yes=100 Partial=50 (awareness at leadership level, no formal accountability)	GV.OV-1 , GV.OV-2	Societal Impacts, Human-AI Config

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	accountable for AI risk?			No=0 Unsure=0, flagged		
G-08	Are AI governance policies communicated to contractors, vendors, and third parties who access company systems?	Govern 1.3	HIGH	Yes=100 Partial=50 (communicated to some vendors) No=0 Unsure=0, flagged	GV.PO-1 , MG.PO-1	Data Privacy, IP Exposure
G-09	Has your organization defined a classification of AI tools by risk tier (e.g. approved, conditional, prohibited)?	Govern 1.1	HIGH	Yes=100 Partial=50 (informal classification exists) No=0 Unsure=0, flagged	GV.PO-1 , MP.AC-1	Data Privacy, Info Security
G-10	Is there a formal process for employees to request approval for a new AI tool before using it?	Govern 1.2	HIGH	Yes=100 Partial=50 (informal request exists, no formal process) No=0 Unsure=0, flagged	GV.OV-2 , MG.PO-1	Data Privacy, IP Exposure

Scoring Detail

ID	Scoring Logic (Yes Partial No Unsure)
G-01	Yes=100 Partial=50 (draft exists, not published) No=0 Unsure=0, flagged

ID	Scoring Logic (Yes Partial No Unsure)
G-02	Yes=100 Partial=50 (informal owner, no formal mandate) No=0 Unsure=0, flagged
G-03	Yes=100 Partial=50 (awareness exists, no formal acknowledgment) No=0 Unsure=0, flagged
G-04	Yes=100 Partial=50 (ad hoc review only) No=0 Unsure=0, flagged
G-05	Yes=100 Partial=50 (general AI policy only, no GenAI specifics) No=0 Unsure=0, flagged
G-06	Yes=100 Partial=50 (policy references HR but no specific consequences) No=0 Unsure=0, flagged
G-07	Yes=100 Partial=50 (awareness at leadership level, no formal accountability) No=0 Unsure=0, flagged
G-08	Yes=100 Partial=50 (communicated to some vendors) No=0 Unsure=0, flagged
G-09	Yes=100 Partial=50 (informal classification exists) No=0 Unsure=0, flagged
G-10	Yes=100 Partial=50 (informal request exists, no formal process) No=0 Unsure=0, flagged

MAP — AI TOOL INVENTORY & RISK AWARENESS

Does the organization understand what AI tools are in use, what data they touch, and what risks they carry?

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
M-01	Has your organization formally inventoried all AI tools in use across departments?	Map 1.1	HIGH	Yes=100 Partial=50 (partial list, not comprehensive) No=0 Unsure=0, flagged	MP.AC-1	Data Privacy, Info Security

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
M-02	Have the data handling practices of each AI tool in use been reviewed?	Map 1.5	HIGH	Yes=100 Partial=50 (some tools reviewed) No=0 Unsure=0, flagged	MP.RD-1	Data Privacy
M-03	Do you understand which AI tools have access to sensitive or confidential company data?	Map 2.2	HIGH	Yes=100 Partial=50 (understood for some tools) No=0 Unsure=0, flagged	MP.AC-1, MP.RD-1	Data Privacy, Prompt Injection
M-04	Has a formal risk assessment been conducted for any AI tool currently in use?	Map 5.1	MEDIUM	Yes=100 Partial=50 (informal assessment only) No=0 Unsure=0, flagged	MP.AI-1	Confabulation, Data Poisoning
M-05	Does your AI inventory include the department, owner, business purpose, and data classification for each tool?	Map 1.1	HIGH	Yes=100 Partial=50 (basic list without full metadata) No=0 Unsure=0, flagged	MP.AC-1, MG.RR-1	Data Privacy, IP Exposure
M-06	Do you know whether each AI tool in use has a	Map 1.5	HIGH	Yes=100 Partial=50 (some tools	MP.RD-1, MG.PO-1	Data Privacy

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	signed data processing agreement (DPA) with your organization?			have DPAs) No=0 Unsure=0, flagged		
M-07	Has your organization identified which AI tools may be processing regulated data (PII, HIPAA, GDPR, CCPA)?	Map 2.2	HIGH	Yes=100 Partial=50 (identified for some tools) No=0 Unsure=0, flagged	MP.AC-1 , MP.RD-1	Data Privacy, Societal Impacts
M-08	Are AI tools used by remote workers or on personal devices tracked and included in the inventory?	Map 1.1	MEDIUM	Yes=100 Partial=50 (corporate devices only) No=0 Unsure=0, flagged	MP.AC-1 , MS.AN-1	Data Privacy, Info Security
M-09	Has your organization evaluated the AI tool supply chain — including third-party models or APIs embedded in approved software?	Map 5.1	HIGH	Yes=100 Partial=50 (top-level tools reviewed, not embedded AI) No=0 Unsure=0, flagged	MP.AI-1 , MP.RD-1	Data Poisoning, Info Security
M-10	Do you have a process to identify when an approved	Map 1.5	MEDIUM	Yes=100 Partial=50 (ad hoc awareness,	MP.RD-1 , MS.MC-1	Data Privacy, Human-AI Config

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	vendor adds AI capabilities to an existing product?			no formal process) No=0 Unsure=0, flagged		

Scoring Detail

ID	Scoring Logic (Yes Partial No Unsure)
M-01	Yes=100 Partial=50 (partial list, not comprehensive) No=0 Unsure=0, flagged
M-02	Yes=100 Partial=50 (some tools reviewed) No=0 Unsure=0, flagged
M-03	Yes=100 Partial=50 (understood for some tools) No=0 Unsure=0, flagged
M-04	Yes=100 Partial=50 (informal assessment only) No=0 Unsure=0, flagged
M-05	Yes=100 Partial=50 (basic list without full metadata) No=0 Unsure=0, flagged
M-06	Yes=100 Partial=50 (some tools have DPAs) No=0 Unsure=0, flagged
M-07	Yes=100 Partial=50 (identified for some tools) No=0 Unsure=0, flagged
M-08	Yes=100 Partial=50 (corporate devices only) No=0 Unsure=0, flagged
M-09	Yes=100 Partial=50 (top-level tools reviewed, not embedded AI) No=0 Unsure=0, flagged
M-10	Yes=100 Partial=50 (ad hoc awareness, no formal process) No=0 Unsure=0, flagged

MEASURE — MONITORING & ONGOING RISK MEASUREMENT

Is the organization actively monitoring AI tool usage and measuring risk over time?

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
ME-01	Is AI tool usage monitored in your	Measure 2.5	HIGH	Yes=100 Partial=50	MS.AN-1	Info Security

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	SIEM, proxy, or equivalent logging system?			(partial monitoring) No=0 Unsure=0, flagged		
ME-02	Do you receive alerts when new or unknown AI tools are accessed on the network?	Measure 2.6	HIGH	Yes=100 Partial=50 (some alerts configured) No=0 Unsure=0, flagged	MS.AN-1	Data Privacy, Info Security
ME-03	Are AI-related security incidents tracked and reviewed on a regular schedule?	Measure 4.1	MEDIUM	Yes=100 Partial=50 (tracked but no regular review cadence) No=0 Unsure=0, flagged	MS.DW-1	Human-AI Config
ME-04	Do you conduct periodic reviews of the AI tool inventory to check for newly adopted tools?	Measure 2.2	MEDIUM	Yes=100 Partial=50 (annual review only) No=0 Unsure=0, flagged	MS.MC-1	Data Poisoning
ME-05	Do you monitor the volume and frequency of data	Measure 2.5	HIGH	Yes=100 Partial=50 (tool access monitored)	MS.AN-1 , MP.RD-1	Data Privacy, IP Exposure

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	being sent to external AI tools?			but not data volume) No=0 Unsure=0, flagged		
ME-06	Are DNS or proxy logs reviewed specifically for AI-related domains on a scheduled basis?	Measure 2.5	HIGH	Yes=100 Partial=50 (general log review, not AI-specific) No=0 Unsure=0, flagged	MS.AN-1	Info Security, Data Privacy
ME-07	Do you have a mechanism to detect when an employee accesses an AI tool from an unmanaged device or personal network?	Measure 2.6	MEDIUM	Yes=100 Partial=50 (managed devices only) No=0 Unsure=0, flagged	MS.AN-1 , MP.AC-1	Data Privacy, Info Security
ME-08	Are AI risk metrics (e.g. number of unapproved tools detected, data volume sent to AI vendors) reported to leadership on a regular basis?	Measure 4.1	MEDIUM	Yes=100 Partial=50 (reported ad hoc, not regularly) No=0 Unsure=0, flagged	MS.DW-1 , GV.OV-1	Societal Impacts, Human-AI Config
ME-09	Has your organization established a	Measure 2.5	MEDIUM	Yes=100 Partial=50 (informal	MS.AN-1 , MS.DW-1	Info Security,

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	baseline of normal AI tool usage to detect anomalies?			awareness, no defined baseline) No=0 Unsure=0, flagged		Data Poisoning
ME-10	Are third-party AI tools re-evaluated when a vendor updates their privacy policy or terms of service?	Measure 2.2	MEDIUM	Yes=100 Partial=50 (re-evaluated for major changes only) No=0 Unsure=0, flagged	MS.MC-1 , MP.RD-1	Data Privacy

Scoring Detail

ID	Scoring Logic (Yes Partial No Unsure)
ME-01	Yes=100 Partial=50 (partial monitoring) No=0 Unsure=0, flagged
ME-02	Yes=100 Partial=50 (some alerts configured) No=0 Unsure=0, flagged
ME-03	Yes=100 Partial=50 (tracked but no regular review cadence) No=0 Unsure=0, flagged
ME-04	Yes=100 Partial=50 (annual review only) No=0 Unsure=0, flagged
ME-05	Yes=100 Partial=50 (tool access monitored but not data volume) No=0 Unsure=0, flagged
ME-06	Yes=100 Partial=50 (general log review, not AI-specific) No=0 Unsure=0, flagged
ME-07	Yes=100 Partial=50 (managed devices only) No=0 Unsure=0, flagged
ME-08	Yes=100 Partial=50 (reported ad hoc, not regularly) No=0 Unsure=0, flagged
ME-09	Yes=100 Partial=50 (informal awareness, no defined baseline) No=0 Unsure=0, flagged

ID	Scoring Logic (Yes Partial No Unsure)
ME-10	Yes=100 Partial=50 (re-evaluated for major changes only) No=0 Unsure=0, flagged

MANAGE — RESPONSE & REMEDIATION CAPABILITY

Does the organization have the processes and capabilities to act on AI risk when it is identified?

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
MG-01	Does your organization have a defined process to block or restrict unauthorized AI tools?	Manage 1.3	HIGH	Yes=100 Partial=50 (manual process, not formalized) No=0 Unsure=0, flagged	MG.AN-1	Data Privacy, Info Security
MG-02	Is there a vendor review process for AI tools before organizational adoption?	Manage 2.2	HIGH	Yes=100 Partial=50 (informal checklist only) No=0 Unsure=0, flagged	MG.PO-1	IP Exposure, Data Privacy
MG-03	Do you have an incident response plan that covers AI-related data exposure events?	Manage 3.1	MEDIUM	Yes=100 Partial=50 (IR plan exists, no AI-specific section) No=0 Unsure=0, flagged	MG.DM-1	Data Privacy, Prompt Injection

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
MG-04	Are AI tool owners formally assigned to maintain accountability for each approved tool?	Manage 4.1	MEDIUM	Yes=100 Partial=50 (informal ownership) No=0 Unsure=0, flagged	MG.RR-1	Human-AI Config
MG-05	When an unauthorized AI tool is detected, is there a documented escalation path and response timeline?	Manage 1.3	HIGH	Yes=100 Partial=50 (escalation path exists, no defined timeline) No=0 Unsure=0, flagged	MG.AN-1 , MG.DM-1	Data Privacy, Info Security
MG-06	Can your organization revoke access to an AI tool across all users within 24 hours of a policy violation or breach?	Manage 1.3	HIGH	Yes=100 Partial=50 (revocation possible but not within 24 hrs) No=0 Unsure=0, flagged	MG.AN-1	Info Security, Data Privacy
MG-07	Does your incident response plan define what constitutes an AI-related security incident (e.g. sensitive data sent to LLM, prompt injection,	Manage 3.1	HIGH	Yes=100 Partial=50 (general definition, no AI-specific criteria) No=0 Unsure=0, flagged	MG.DM-1	Prompt Injection, Data Privacy, Info Security

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	unauthorized tool)?					
MG-08	After an AI-related incident, does your organization conduct a post-incident review and update controls?	Manage 4.1	MEDIUM	Yes=100 Partial=50 (review conducted, controls not always updated) No=0 Unsure=0, flagged	MG.RR-1 , MS.DW-1	Data Poisoning, Info Security
MG-09	Is there a process for employees to report suspected AI misuse or policy violations?	Manage 3.1	MEDIUM	Yes=100 Partial=50 (general reporting channel, not AI-specific) No=0 Unsure=0, flagged	MG.DM-1 , GV.AT-1	Harmful Content, Info Integrity
MG-10	Are firewall or DNS blocking rules for unauthorized AI tools tested and verified to be effective?	Manage 1.3	HIGH	Yes=100 Partial=50 (rules exist but not regularly tested) No=0 Unsure=0, flagged	MG.AN-1	Info Security, Data Privacy

Scoring Detail

ID	Scoring Logic (Yes Partial No Unsure)
MG-01	Yes=100 Partial=50 (manual process, not formalized) No=0 Unsure=0, flagged
MG-02	Yes=100 Partial=50 (informal checklist only) No=0 Unsure=0, flagged
MG-03	Yes=100 Partial=50 (IR plan exists, no AI-specific section) No=0 Unsure=0, flagged
MG-04	Yes=100 Partial=50 (informal ownership) No=0 Unsure=0, flagged
MG-05	Yes=100 Partial=50 (escalation path exists, no defined timeline) No=0 Unsure=0, flagged
MG-06	Yes=100 Partial=50 (revocation possible but not within 24 hrs) No=0 Unsure=0, flagged
MG-07	Yes=100 Partial=50 (general definition, no AI-specific criteria) No=0 Unsure=0, flagged
MG-08	Yes=100 Partial=50 (review conducted, controls not always updated) No=0 Unsure=0, flagged
MG-09	Yes=100 Partial=50 (general reporting channel, not AI-specific) No=0 Unsure=0, flagged
MG-10	Yes=100 Partial=50 (rules exist but not regularly tested) No=0 Unsure=0, flagged

GENAI — GENERATIVE AI SPECIFIC CONTROLS

Does the organization have specific controls for the risks introduced by generative AI tools — LLMs, image generators, voice synthesis, video generation, and code assistants?

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
GA-01	Does your organization have a policy that	Govern 1.1	HIGH	Yes=100 Partial=50 (policy mentions AI	GV.PO-1	Info Integrity, Harmful Content,

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	addresses AI-generated media, including deepfakes and synthetic images?			media but no deepfake specifics) No=0 Unsure=0, flagged		Human Replication
GA-02	Do you have controls in place around AI voice synthesis or audio cloning tools?	Govern 1.1	HIGH	Yes=100 Partial=50 (aware of risk, no formal controls) No=0 Unsure=0, flagged	GV.PO-1 , GV.AT-1	Human Replication, Info Integrity
GA-03	Are guest and contractor accounts restricted from accessing AI tools on the corporate network?	Manage 1.3	HIGH	Yes=100 Partial=50 (restricted for some AI tools) No=0 Unsure=0, flagged	MG.AN-1 , MP.AC-1	Data Privacy, Info Security
GA-04	Do you have a process to investigate and identify unrecognized or unclassified AI tool traffic in network logs?	Map 1.1	HIGH	Yes=100 Partial=50 (manual investigation only) No=0 Unsure=0, flagged	MP.AC-1 , MS.AN-1	Data Poisoning, Info Security

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
GA-05	Are employees prohibited from entering personal identifiable information (PII) into consumer AI tools that lack a signed DPA?	Govern 1.1	HIGH	Yes=100 Partial=50 (guidance given but not formally prohibited) No=0 Unsure=0, flagged	GV.PO-1 , MP.RD-1	Data Privacy
GA-06	Are employees prohibited from entering proprietary source code, trade secrets, or confidential documents into AI coding assistants or LLMs?	Govern 1.1	HIGH	Yes=100 Partial=50 (guidance given but not formally prohibited) No=0 Unsure=0, flagged	GV.PO-1 , MP.RD-1	IP Exposure, Info Security
GA-07	Does your organization have guidance on verifying AI-generated outputs before acting on them or	Govern 1.3	MEDIUM	Yes=100 Partial=50 (informal guidance, not documented) No=0 Unsure=0, flagged	GV.AT-1 , GV.PO-1	Confabulation, Info Integrity, Human-AI Config

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	sharing them externally?					
GA-08	Are employees trained specifically on the risks of prompt injection attacks in AI tools they use?	Govern 1.3	HIGH	Yes=100 Partial=50 (general security training, not prompt injection specific) No=0 Unsure=0, flagged	GV.AT-1	Prompt Injection, Info Security
GA-09	Does your organization have a policy covering the use of AI tools for customer-facing communications or content?	Govern 1.1	HIGH	Yes=100 Partial=50 (informal guidance only) No=0 Unsure=0, flagged	GV.PO-1 , GV.AT-1	Info Integrity, Confabulation, Human Replication
GA-10	Are there controls preventing AI tools from being used to generate content that impersonates company executives or	Govern 1.1	HIGH	Yes=100 Partial=50 (policy exists, no technical controls) No=0 Unsure=0, flagged	GV.PO-1 , MG.AN-1	Human Replication, Info Integrity, Harmful Content

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	brand identity?					
GA-11	Has your organization evaluated whether any AI tools in use have the potential to produce CBRN-relevant information without restriction?	Map 5.1	HIGH	Yes=100 Partial=50 (awareness but no formal evaluation) No=0 Unsure=0, flagged	MP.AI-1 , GV.PO-1	CBRN Info
GA-12	Do you have a process to evaluate whether AI-assisted decisions (hiring, performance, access) introduce bias or discriminatory outcomes?	Map 5.1	MEDIUM	Yes=100 Partial=50 (awareness, no formal evaluation process) No=0 Unsure=0, flagged	MP.AI-1 , GV.OV-1	Societal Impacts

Scoring Detail

ID	Scoring Logic (Yes Partial No Unsure)
GA-01	Yes=100 Partial=50 (policy mentions AI media but no deepfake specifics) No=0 Unsure=0, flagged
GA-02	Yes=100 Partial=50 (aware of risk, no formal controls) No=0 Unsure=0, flagged
GA-03	Yes=100 Partial=50 (restricted for some AI tools) No=0 Unsure=0, flagged
GA-04	Yes=100 Partial=50 (manual investigation only) No=0 Unsure=0, flagged
GA-05	Yes=100 Partial=50 (guidance given but not formally prohibited) No=0 Unsure=0, flagged
GA-06	Yes=100 Partial=50 (guidance given but not formally prohibited) No=0 Unsure=0, flagged
GA-07	Yes=100 Partial=50 (informal guidance, not documented) No=0 Unsure=0, flagged
GA-08	Yes=100 Partial=50 (general security training, not prompt injection specific) No=0 Unsure=0, flagged
GA-09	Yes=100 Partial=50 (informal guidance only) No=0 Unsure=0, flagged
GA-10	Yes=100 Partial=50 (policy exists, no technical controls) No=0 Unsure=0, flagged
GA-11	Yes=100 Partial=50 (awareness but no formal evaluation) No=0 Unsure=0, flagged
GA-12	Yes=100 Partial=50 (awareness, no formal evaluation process) No=0 Unsure=0, flagged

VENDOR — PROCUREMENT & THIRD-PARTY AI CONTROLS

Does the organization evaluate and manage AI risk introduced through vendor products, third-party APIs, and embedded AI capabilities?

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
V-01	Does your vendor review process include a specific AI security checklist covering data handling, model training practices, and regulatory compliance?	Manage 2.2	HIGH	Yes=100 Partial=50 (general vendor review, no AI-specific checklist) No=0 Unsure=0, flagged	MG.PO-1, MP.RD-1	Data Privacy, Data Poisoning
V-02	Do you require AI vendors to disclose whether customer data is used to train or fine-tune models?	Manage 2.2	HIGH	Yes=100 Partial=50 (asked informally, not contractually required) No=0 Unsure=0, flagged	MG.PO-1, MP.RD-1	Data Privacy, Data Poisoning
V-03	Is SOC 2 Type II compliance (or equivalent) required for AI vendors who process company data?	Manage 2.2	HIGH	Yes=100 Partial=50 (required for some vendors) No=0 Unsure=0, flagged	MG.PO-1	Info Security, Data Privacy

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
V-04	Are AI vendors contractually required to notify your organization of a data breach within a defined timeframe?	Manage 3.1	HIGH	Yes=100 Partial=50 (some vendor contracts include breach notice) No=0 Unsure=0, flagged	MG.DM-1 , MG.PO-1	Data Privacy, Info Security
V-05	Do contracts with AI vendors include the right to audit their data handling and security practices?	Manage 2.2	MEDIUM	Yes=100 Partial=50 (right to audit in some contracts) No=0 Unsure=0, flagged	MG.PO-1 , MP.RD-1	Data Privacy
V-06	Is there a process to re-evaluate AI vendor risk when they are acquired, undergo significant changes, or release major model updates?	Manage 2.2	MEDIUM	Yes=100 Partial=50 (re-evaluated for acquisitions only) No=0 Unsure=0, flagged	MG.PO-1 , MS.MC-1	Data Privacy, Data Poisoning
V-07	Do you know whether your approved AI vendors subcontract any AI processing to	Map 5.1	HIGH	Yes=100 Partial=50 (asked but not always disclosed) No=0	MP.AI-1 , MG.PO-1	Data Privacy, Data Poisoning, Info Security

ID	Question	NIST Ref	Gap	Scoring Logic	NIST Controls	GenAI Risks
	fourth-party providers?			Unsure=0, flagged		
V-08	Are AI features embedded in non-AI software (e.g. AI summaries in productivity tools, AI suggestions in CRM) tracked and governed under your AI policy?	Map 1.1	HIGH	Yes=100 Partial=50 (some embedded AI tracked) No=0 Unsure=0, flagged	MP.AC-1 , GV.PO-1	Data Privacy, Human-AI Config, IP Exposure
V-09	Does your organization have a maximum data retention requirement that AI vendors must contractually agree to?	Manage 2.2	MEDIUM	Yes=100 Partial=50 (retention discussed, not contractually enforced) No=0 Unsure=0, flagged	MG.PO-1 , MP.RD-1	Data Privacy
V-10	Is there a formal offboarding process when an AI tool or vendor relationship is terminated, including data deletion verification?	Manage 4.1	MEDIUM	Yes=100 Partial=50 (offboarding exists, no data deletion verification) No=0 Unsure=0, flagged	MG.RR-1 , MP.RD-1	Data Privacy, IP Exposure

Scoring Detail

ID	Scoring Logic (Yes Partial No Unsure)
V-01	Yes=100 Partial=50 (general vendor review, no AI-specific checklist) No=0 Unsure=0, flagged
V-02	Yes=100 Partial=50 (asked informally, not contractually required) No=0 Unsure=0, flagged
V-03	Yes=100 Partial=50 (required for some vendors) No=0 Unsure=0, flagged
V-04	Yes=100 Partial=50 (some vendor contracts include breach notice) No=0 Unsure=0, flagged
V-05	Yes=100 Partial=50 (right to audit in some contracts) No=0 Unsure=0, flagged
V-06	Yes=100 Partial=50 (re-evaluated for acquisitions only) No=0 Unsure=0, flagged
V-07	Yes=100 Partial=50 (asked but not always disclosed) No=0 Unsure=0, flagged
V-08	Yes=100 Partial=50 (some embedded AI tracked) No=0 Unsure=0, flagged
V-09	Yes=100 Partial=50 (retention discussed, not contractually enforced) No=0 Unsure=0, flagged
V-10	Yes=100 Partial=50 (offboarding exists, no data deletion verification) No=0 Unsure=0, flagged

CONDITIONAL — TRIGGERED BY DETECTION RESULTS

These questions are added dynamically based on what the DNS scan detects. They only appear when the relevant tool category or user pattern is found in logs.

Conditional questions are added at the end of the relevant NIST section only when the specified condition is detected in the DNS log scan. They do not appear for every assessment.

ID	Question	NIST Ref	Gap	Trigger Condition	NIST Controls	GenAI Risks
C-01	Do you have a policy that addresses AI-generated media, including deepfakes and synthetic images?	Govern 1.1	HIGH	Image generation tool detected (e.g. Midjourney, Stable Diffusion)	GV.PO-1	Info Integrity, Harmful Content, Human Replication
C-02	Do you have controls in place around AI voice synthesis or audio cloning tools?	Govern 1.1	HIGH	Voice/audio generation tool detected (e.g. ElevenLabs, Murf AI)	GV.PO-1	Human Replication, Info Integrity
C-03	Are guest and contractor accounts restricted from accessing AI tools on the corporate network?	Manage 1.3	HIGH	'guest' username observed in detection results	MG.AN-1	Data Privacy, Info Security

ID	Question	NIST Ref	Gap	Trigger Condition	NIST Controls	GenAI Risks
C-04	Do you have a process to investigate and identify unrecognized or unclassified AI tool traffic?	Map 1.1	HIGH	Unknown/unclassified domain detected in logs	MP.AC-1	Data Poisoning, Info Security
C-05	Do you have specific controls governing the use of AI coding assistants that send code context to external cloud APIs?	Govern 1.1	HIGH	Code assistant tool detected (e.g. Cursor, GitHub Copilot, Replit)	GV.PO-1 , MP.RD-1	IP Exposure, Info Security
C-06	Are open source AI models downloaded or self-hosted by your organization subject to the same governance review as commercial tools?	Map 5.1	HIGH	OSS model host detected (e.g. Hugging Face, Replicate, Together AI)	MP.AI-1 , GV.PO-1	Confabulation, Data Poisoning, CBRN Info

ID	Question	NIST Ref	Gap	Trigger Condition	NIST Controls	GenAI Risks
C-07	Does your organization have a policy for AI tools used in meeting transcription or recording that may capture confidential conversations?	Govern 1.1	HIGH	Transcription tool detected (e.g. Otter.ai, Fireflies.ai)	GV.PO-1, MP.AC-1	Data Privacy, Human Replication